Bloque 3: Metodologías de Modelado de Amenazas (Threat Modeling)

FADENA

Process for Attack Simulation and Threat Analysis

Ing. Roxana Quiroga Sollinger

Parte



Módulo 5: PASTA

5.1 PASTA

5.2 Las 7 Etapas de PASTA



5.2 Las 7 Etapas de PASTA

Etapas de PASTA



Process for Attack Simulation and Threat Analysis

Un enfoque centrado en el riesgo

Proceso de modelado de amenazas destinado a considerar posibles escenarios de amenazas, ataques y vulnerabilidades dentro de un entorno de aplicación web en desarrollo o existente con el propósito de evaluar los riesgos y gestionar los impactos técnicos y comerciales.



5.2 Las 7 Etapas de PASTA

Etapa I: Definir Objetivos (DO)

Esta etapa define las metas para analizar y gestionar los riesgos de ciberseguridad de la aplicación evaluada.

Requisitos de Negocio

Evalúan el valor estratégico de la aplicación y sus funcionalidades críticas (como transacciones financieras) para cuantificar impactos económicos y de continuidad, alineando los niveles de servicio y riesgo con las exigencias de organismos reguladores locales (como el BCRA, CNV o la SSN).

Políticas y Normas Internas

Definen las reglas de seguridad de la organización para resguardar la confidencialidad, integridad y disponibilidad de la información en el ciclo de vida del software (SDLC). Adoptan marcos de referencia nacionales (como las pautas del CERT.ar o estándares informáticos de la ONTI) junto con alertas de ciberamenazas del sector.

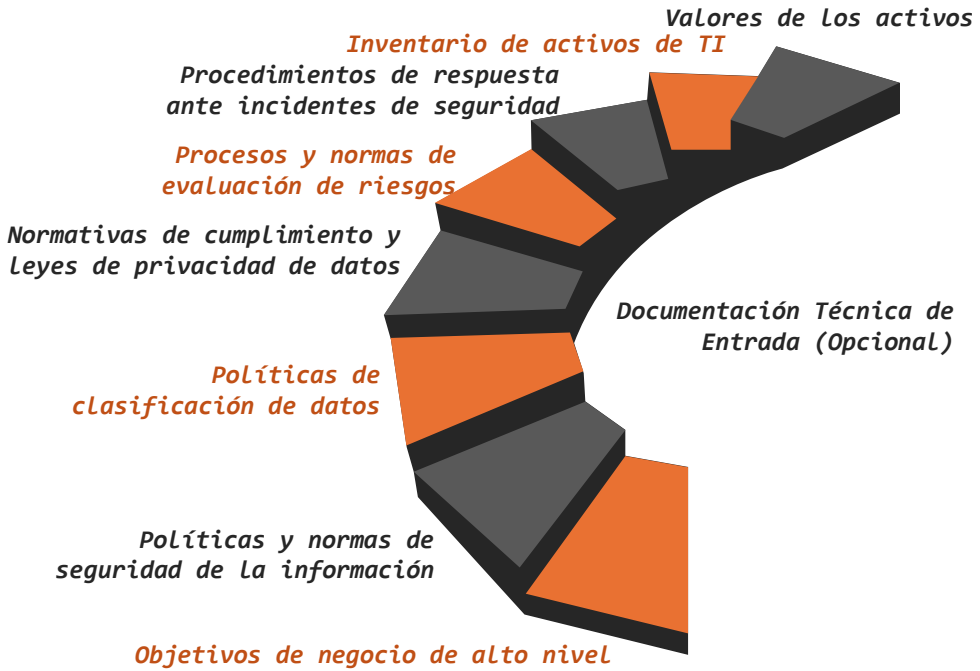
Gobernanza y Cumplimiento

Determinan los controles legales obligatorios en la República Argentina, destacando la Ley N° 25.326 (Protección de Datos Personales) y las resoluciones de la AAIP (Agencia de Acceso a la Información Pública), la Ley N° 26.388 (Delitos Informáticos), y normativas bancarias/financieras del BCRA (como las Comunicaciones "A" 4609, "A" 7724 o regulaciones para Proveedores de Servicios de Pago)

5.2 Las 7 Etapas de PASTA

Etapa I: Definir Objetivos (DO)

Artefactos Tecnológicos de Entrada (Input)



Las entradas de esta etapa abarcan la información técnica, normativa y estratégica necesaria para fundamentar el análisis de riesgos. Si esta información no se encuentra previamente documentada, debe obtenerse mediante entrevistas con las partes interesadas (stakeholders) clave

01 UNIDADES DE DESARROLLO DE APLICACIONES

02 PROPIETARIOS DE NEGOCIO DE LA APLICACIÓN

03 EQUIPOS DE SEGURIDAD DE LA INFORMACIÓN

04 RESPONSABLES DE CONTINUIDAD DEL NEGOCIO

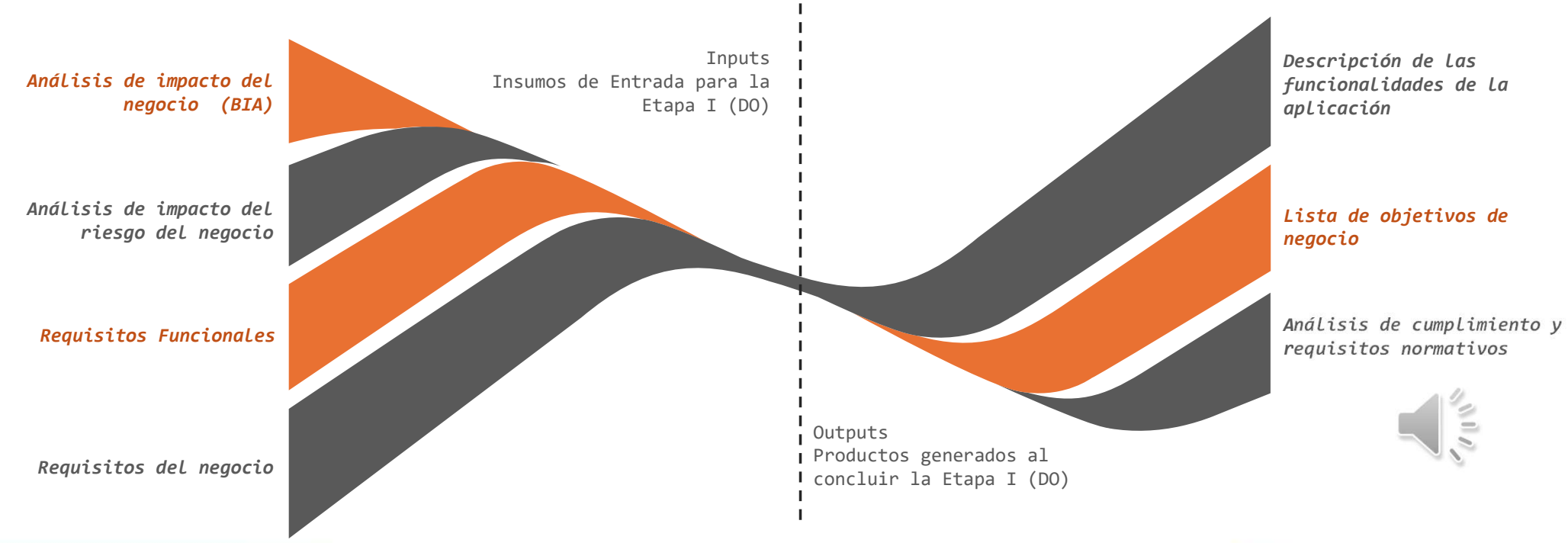
05 GESTORES DE RIESGO

05 OFICIALES DE CUMPLIMIENTO

5.2 Las 7 Etapas de PASTA

Etapa I: Definir Objetivos (DO)

Artefactos de Entrada - Salida



5.2 Las 7 Etapas de PASTA

Etapa I: Definir Objetivos (DO)

Actividades

DO 1.1 - Documentación de Requisitos de Negocio

Registrar las funcionalidades y servicios que la aplicación ofrece a sus usuarios desde la perspectiva comercial

DO 1.2 – Definir los requisitos de seguridad

Definir las pautas de protección para garantizar los pilares de CIA y trazabilidad (accountability) de los datos procesados, transmitidos y almacenados por la aplicación.



DO 1.3 - Definición de Impactos en el Negocio

Evaluar y cuantificar las consecuencias potenciales (financieras y operativas) para la organización si un incidente de seguridad compromete activos de datos valiosos o funcionalidades críticas.

DO 1.4 – Determinación del perfil de riesgo

Identificar y clasificar los riesgos técnicos y de negocio asociados a la aplicación para guiar y priorizar la evaluación de ciberamenazas.

5.2 Las 7 Etapas de PASTA

Etapa II: Definición del Alcance Técnico (DTS)

El objetivo de esta etapa es definir el alcance técnico del ejercicio de modelado de amenazas mediante la identificación detallada de los componentes de arquitectura y software que conforman el sistema.

Delimitar el Stack Tecnológico

Identificar todos los elementos que sostienen la aplicación, incluyendo capas de software, procesos, servidores, sistemas y componentes de red.

Elaborar un inventario de activos

Crear una lista exhaustiva de los componentes tecnológicos que conforman la arquitectura de la aplicación.

Validar contra requisitos

Contrastar los detalles técnicos recopilados en el diseño con los requisitos de seguridad establecidos previamente

Proveer insumos para etapas futuras

Estructurar la información técnica necesaria para la descomposición de la aplicación (Etapa III) y la evaluación de la exposición a amenazas (Etapa IV).

5.2 Las 7 Etapas de PASTA

Etapa II: Definición del Alcance Técnico (DTS)

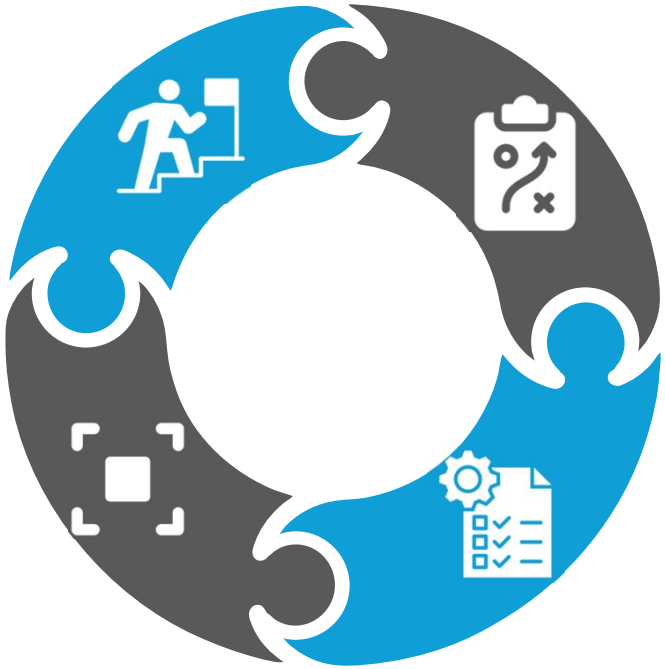
Guia de Ejecución

Propósito y Enfoque

Generar un inventario exhaustivo de activos de hardware y software que elimina los puntos ciegos tecnológicos y define la superficie de ataque requerida para construir los futuros árboles de ataque.

Alcance de Activos

Incluir todas las capas del sistema, abarcando desde la infraestructura de red física hasta los componentes de software integrados y la capa de presentación del cliente.



Estrategia de Ejecución y Criterios de Éxito

Integración de pruebas automatizadas de análisis estático (SAST), dinámico (DAST) y de composición de software (SCA) en el pipeline de CI/CD.

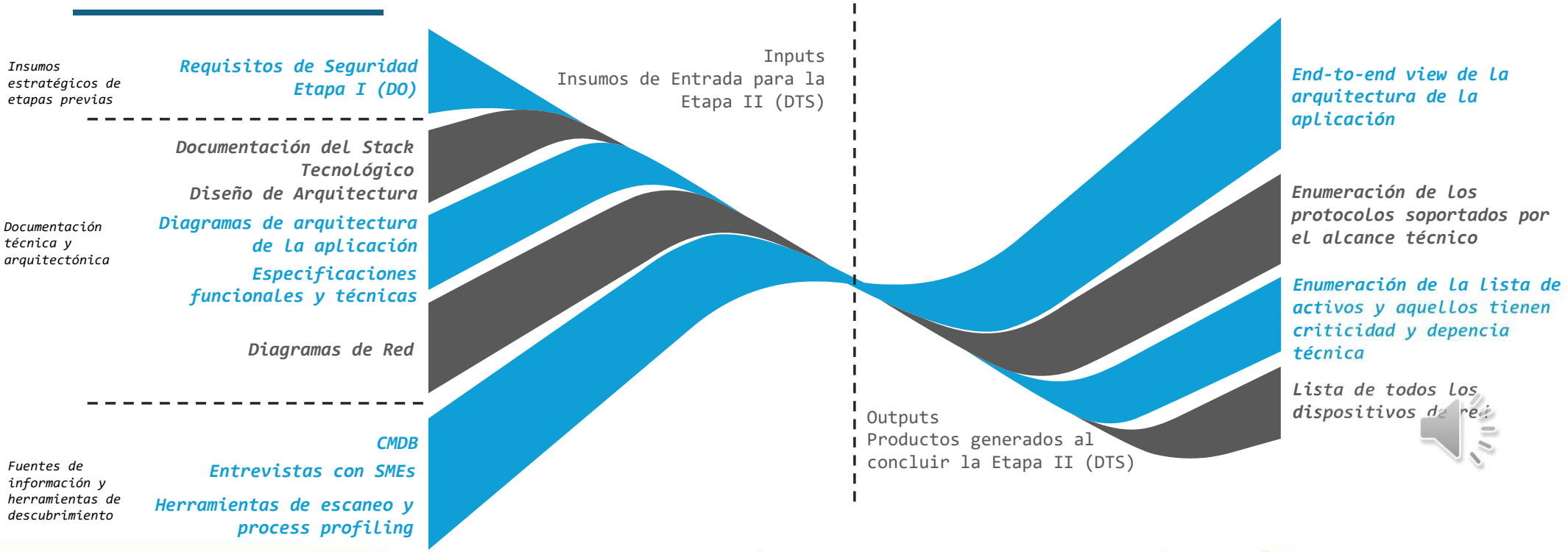
Insumos y Documentación Técnica Requerida

Security by Default es Configuración del sistema reduciendo al mínimo la superficie de ataque y aplicando el principio de mínimo privilegio de origen.

5.2 Las 7 Etapas de PASTA

Etapa II: Definición del Alcance Técnico (DTS)

Artefactos de Entrada - Salida



5.2 Las 7 Etapas de PASTA

Etapa II: Definición del Alcance Técnico (DTS)

Actividades

DTS 2.1 - Enumerar los componentes de software

Recopilar y enumerar todos los componentes de software de la aplicación

DTS 2.2 – Identificación de actores y fuentes/destinos de datos

Identificar y enumerar de forma exhaustiva a todos los actores y determinar sus roles y permisos de acceso a los recursos.

DTS 2.3 – Enumerar servicios a nivel de sistema

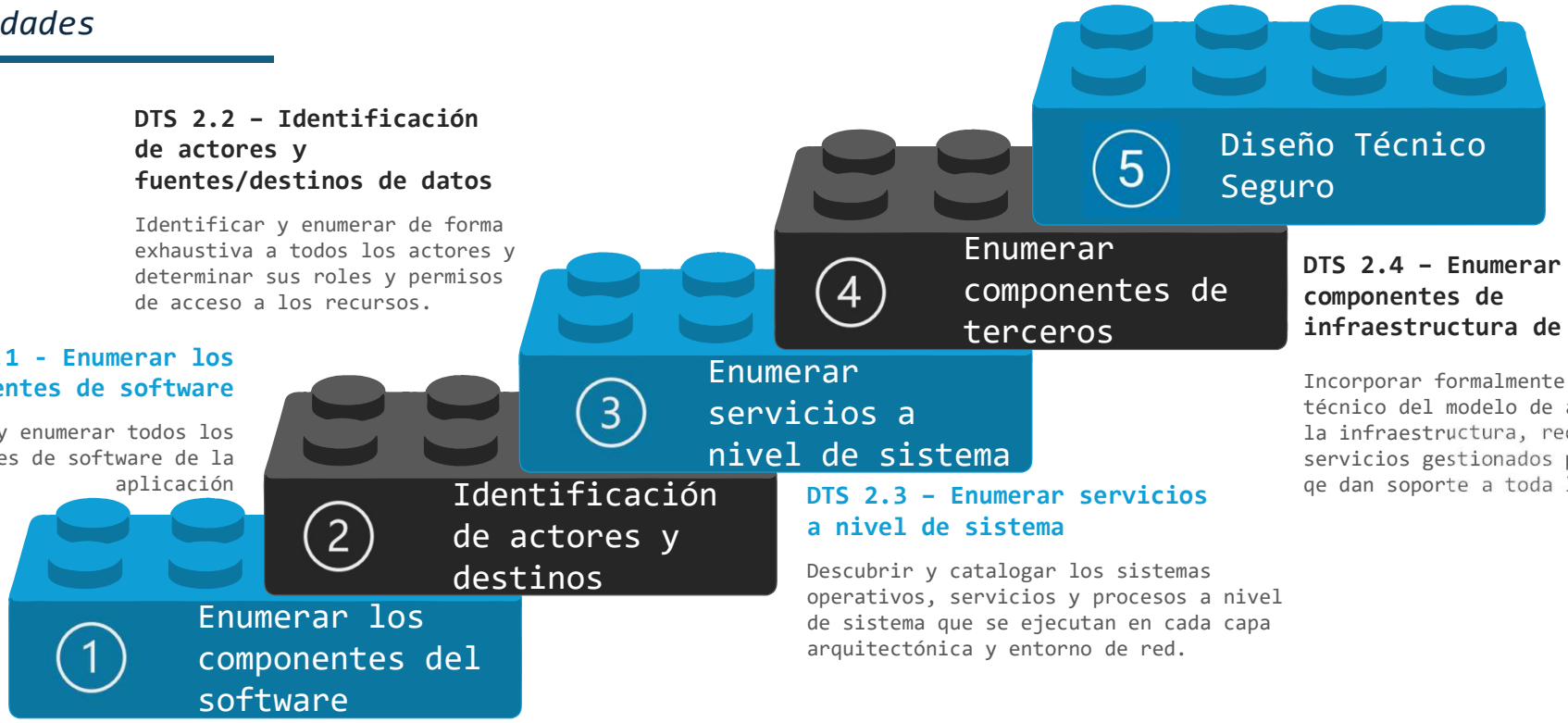
Descubrir y catalogar los sistemas operativos, servicios y procesos a nivel de sistema que se ejecutan en cada capa arquitectónica y entorno de red.

DTS 2.4 – Enumerar los componentes de infraestructura de terceros

Incorporar formalmente al alcance técnico del modelo de amenazas toda la infraestructura, redes y servicios gestionados por terceros qe dan soporte a toda la solución.

DTS 2.5 – Confirmar la integridad de un diseño técnico seguro

Revisar y validar que la documentación del diseño técnico sea completa, precisa y suficiente para sustentar el modelado de amenazas



FADENA



5.2 Las 7 Etapas de PASTA

Etapa III: Descomposición y Análisis de la Aplicación (ADA)

Subdividir el sistema en sus componentes fundamentales —tales como usuarios, roles, flujos de datos, data storage, funciones, controles de seguridad y límites de confianza— para analizar individualmente su postura de seguridad y evaluar cómo interactúan entre sí.



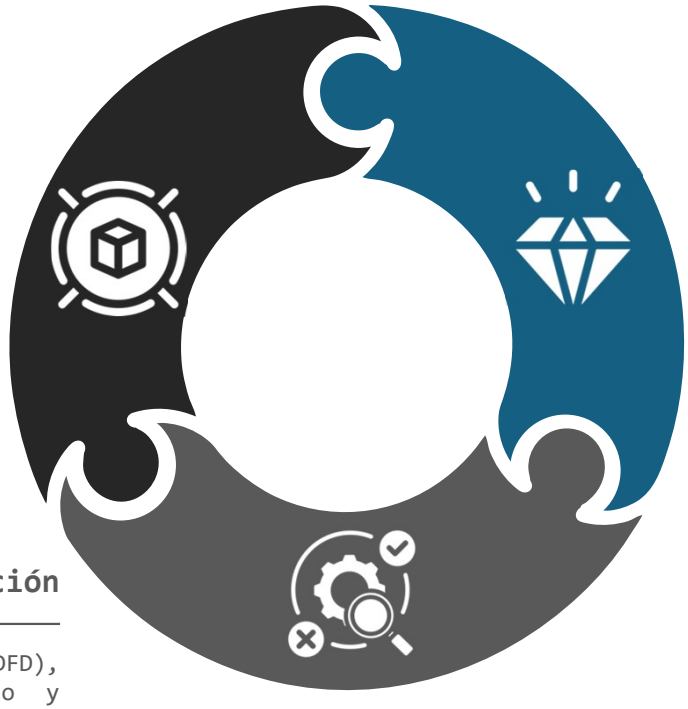
5.2 Las 7 Etapas de PASTA

Etapa III: Descomposición y Análisis de la Aplicación (ADA)

Guia de Ejecución

Componentes objeto de análisis

Usuarios y roles, activos de datos (en reposo y en tránsito), casos de uso y funcionalidades, controles de seguridad, flujos de datos (puntos de entrada y salida) y límites de confianza.



Propósito y valor

Aplicar la seguridad desde el diseño garantizando la confidencialidad, integridad y disponibilidad (CIA) en cada componente, permitiendo evaluar tempranamente el impacto de las vulnerabilidades y defectos de diseño ante posibles ataques.

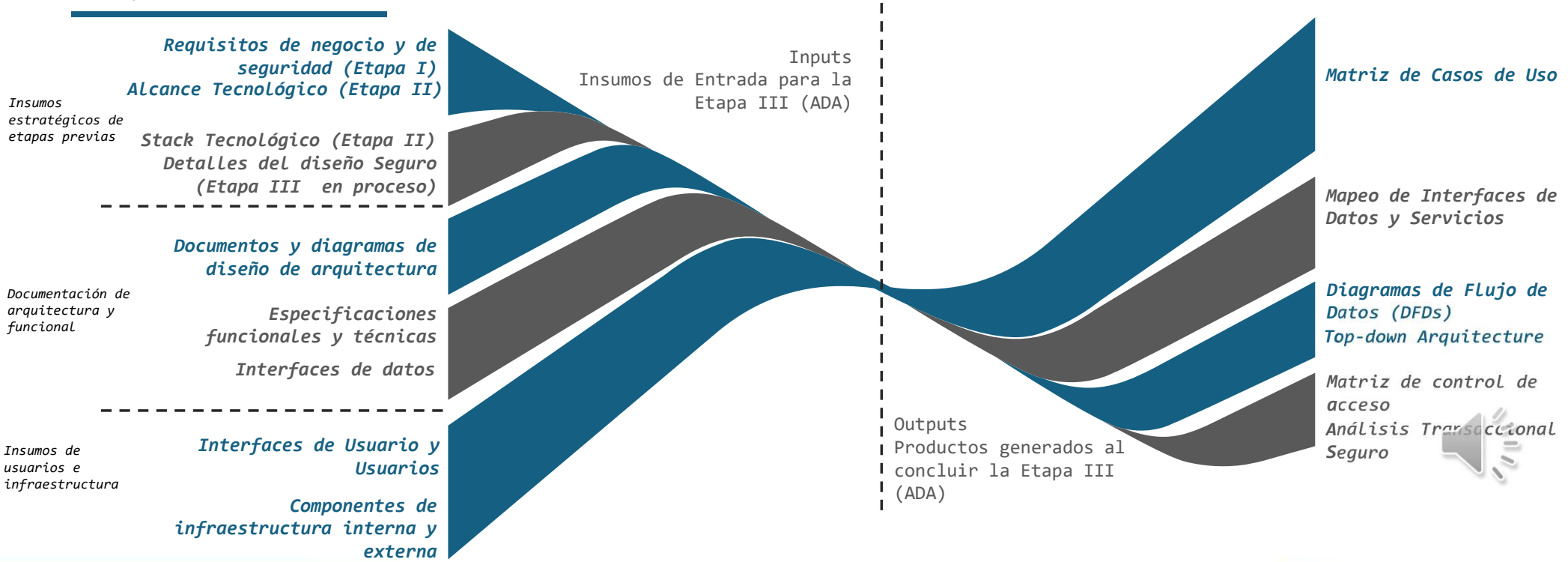
Técnicas de evaluación

Uso de Diagramas de Flujo de Datos (DFD), revisiones del diseño arquitectónico y sesiones para analizar las interfaces, servidores web/aplicaciones, bases de datos y servicios backend.

5.2 Las 7 Etapas de PASTA

Etapa III: Descomposición y Análisis de la Aplicación (ADA)

Artefactos de Entrada - Salida



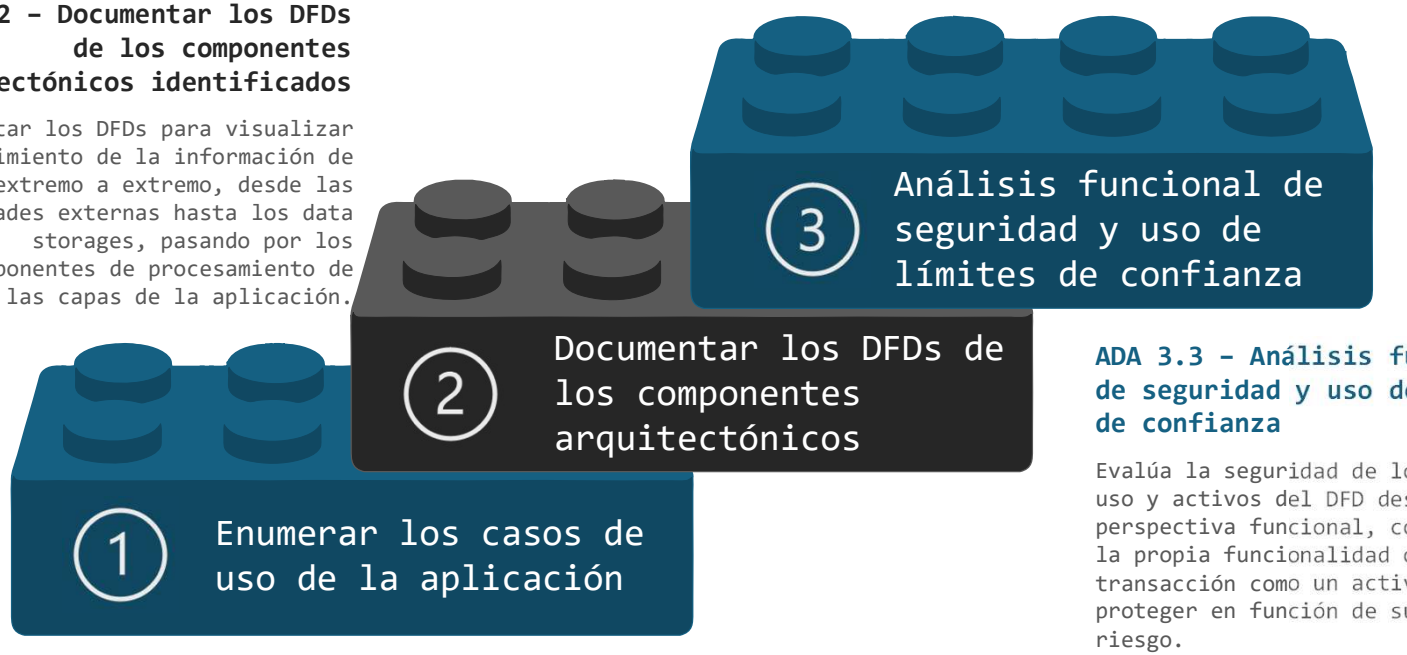
5.2 Las 7 Etapas de PASTA

Etapa III: Descomposición y Análisis de la Aplicación (ADA)

Actividades

ADA 3.2 – Documentar los DFDs de los componentes arquitectónicos identificados

Documentar los DFDs para visualizar el movimiento de la información de extremo a extremo, desde las entidades externas hasta los data storages, pasando por los componentes de procesamiento de todas las capas de la aplicación.



ADA 3.1 – Enumerar los casos de uso de la aplicación

Registrar las funcionalidades y servicios que la aplicación ofrece a sus usuarios desde la perspectiva comercial

ADA 3.3 – Análisis funcional de seguridad y uso de límites de confianza

Evalúa la seguridad de los casos de uso y activos del DFD desde una perspectiva funcional, considerando la propia funcionalidad o transacción como un activo a proteger en función de su perfil de riesgo.

5.2 Las 7 Etapas de PASTA

Etapa IV: Análisis de Riesgo (TA)

Esta etapa tiene como objetivo evaluar los escenarios y agentes de amenaza para determinar la probabilidad e impacto real de un ataque sobre los activos y funcionalidades del sistema.

Análisis de agentes y escenarios de amenaza

Identificar actores de amenaza y sus motivaciones utilizando inteligencia de amenazas interna y externa, analizando cómo intentan explotar vulnerabilidades, fallos de diseño y debilidades en los controles de seguridad.

Actualización de la biblioteca de amenazas

Registrar y enriquecer el catálogo de amenazas de la organización con la información de los agentes y sus objetivos, sirviendo de insumo clave para las revisiones de diseño arquitectónico.

Estimación de probabilidad e impacto

Analizar la frecuencia de eventos de amenaza e inteligencia recopilada para calcular la probabilidad de un ataque, evaluando el riesgo y el impacto potencial sobre los datos y las funciones que están dentro del alcance.

5.2 Las 7 Etapas de PASTA

Etapa IV: Análisis de Riesgo (TA)

Guia de Ejecución

Identificación y caracterización de agentes

Catalogar actores, analizando si actúan de forma intencionada u oportunista a partir de sus capacidades, motivaciones y oportunidades.

Inteligencia de amenazas e incidentes

Utilizar fuentes de inteligencia internas y externas (como ISACs o bases de incidentes como WHID) para evaluar la gravedad de las amenazas y definir respuestas proactivas.

Monitoreo y correlación de eventos

Auditar comportamientos anómalos (violaciones de control de acceso, picos inusuales de tráfico) y utilizar modelos de cadena de ataque (attack chain) para identificar el curso de acción de un atacante.



Cálculo del Riesgo

Determinar el nivel de riesgo integrando la probabilidad de materialización de la amenaza con el impacto técnico y de negocio, validando si los controles existentes reducen o incrementan dicha exposición.

Metodología de puntuación de amenazas

Promediar factores como motivo, oportunidad, habilidad requerida y tamaño de la población y categorizar amenazas técnicas *mediante* STRIDE.

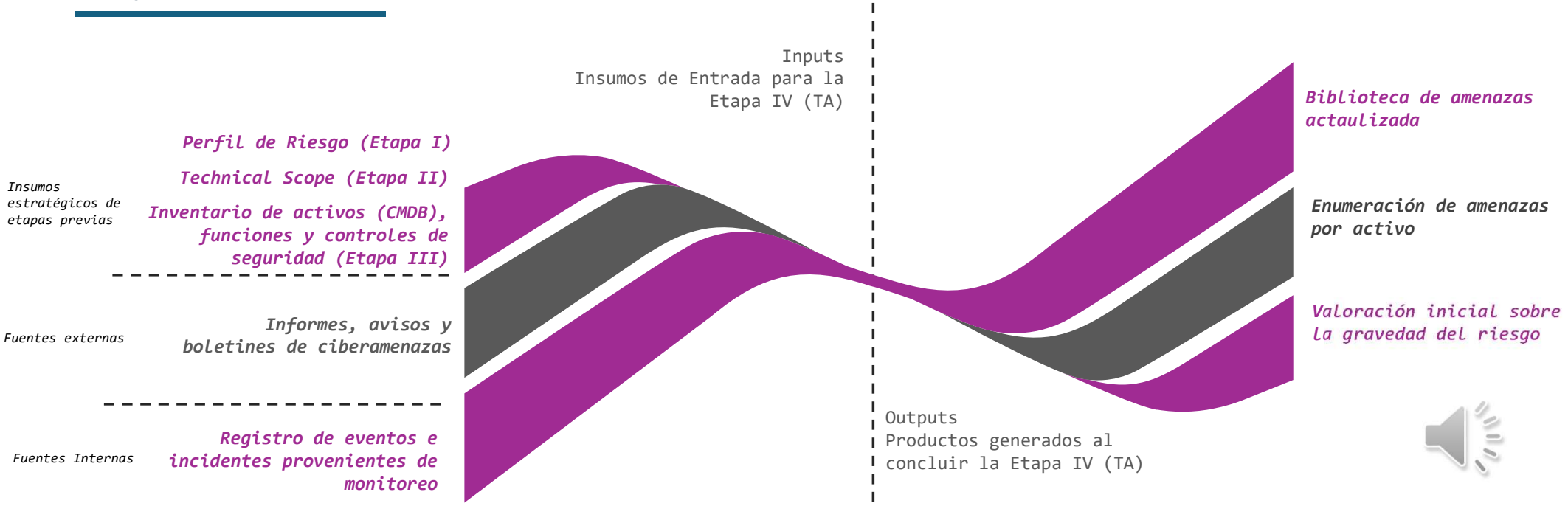
Bibliotecas y repositorios estructurados

Utilizar estándares (como STIX) para alimentar bibliotecas de conocimiento que correlacionen vectores de ataque, observables e indicadores con las vulnerabilidades y controles de la aplicación.

5.2 Las 7 Etapas de PASTA

Etapa IV: Análisis de Riesgo (TA)

Artefactos de Entrada - Salida



5.2 Las 7 Etapas de PASTA

Etapa IV: Análisis de Riesgo (TA)

Actividades

TA 4.1 - Analizar el escenario general de amenazas

Representación gráfica para identificar el impacto real de las aplicaciones web.

TA 4.2 – Recopilar información sobre amenazas a partir de fuentes internas

Recopilación de inteligencia de amenazas a partir de fuentes de información internas de la organización para detectar y responder a incidentes de seguridad.

TA 4.3 – Recopilar información sobre amenazas proveniente de fuentes externas

Recolección, categorización e intercambio de inteligencia de ciberamenazas procedentes de fuentes externas a la organización.

TA 4.5 – Mapeo de agentes de amenazas a activos

Describe la relación entre las amenazas identificadas y los activos o vulnerabilidades del sistema para fundamentar el análisis inicial de riesgos.



TA 4.4 – Actualizar bibliotecas de amenazas

Mantenimiento y la actualización continua de las bibliotecas de amenazas con datos sobre riesgos emergentes para ofrecer información accionable orientada a la mitigación.

TA 4.6 – Asignación de valores probabilísticos a las amenazas identificadas

Detalla la evaluación de la probabilidad y el impacto de amenazas específicas sobre los activos valiosos y las operaciones críticas de la organización.

5.2 Las 7 Etapas de PASTA

Etapa V: Análisis de debilidades y vulnerabilidades (WVA)

Esta etapa tiene por objetivo el análisis de debilidades y vulnerabilidades, así como su correlación con las amenazas analizadas previamente.

Identificar y consolidar debilidades

Detectar fallas en la arquitectura del sistema e integrar hallazgos de evaluaciones previas.

Correlacionar

Cruzar las vulnerabilidades encontradas con las amenazas previamente analizadas.

Priorizar

Clasificar las debilidades clave para determinar cuáles deben ser probadas o validadas.

5.2 Las 7 Etapas de PASTA

Etapa V: Análisis de debilidades y vulnerabilidades (WVA)

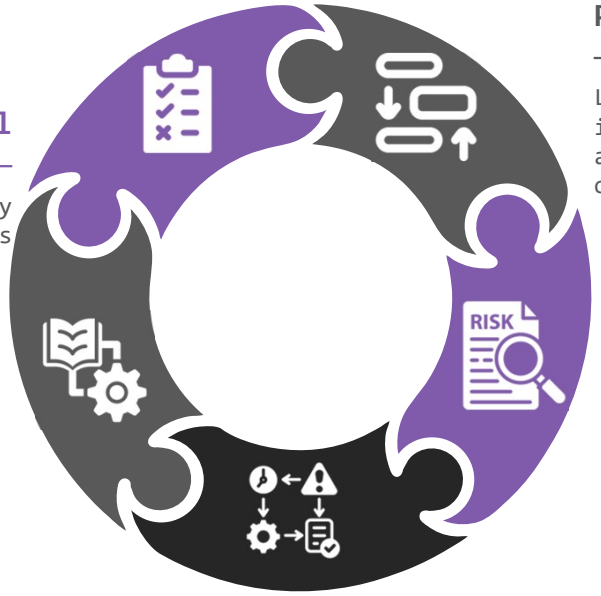
Guia de Ejecución

Reevaluación y correlación contextual

Examinar vulnerabilidades del stack tecnológico y defectos de diseño. Se cruzan con pruebas realistas para definir casos de prueba realista.

Integración de fuentes previas

Se incorporan análisis anteriores (revisiones de código, revisiones arquitectónicas, pruebas SAST y DAST). Estos datos se centralizan en una base de conocimiento organizada y consultable por activo.



Priorización del alcance de pruebas

Las vulnerabilidades con mayor probabilidad e impacto técnico se seleccionan para formar el alcance de pruebas de seguridad adicionales, orientadas a validar su explotabilidad directa.

Evaluación de severidad y riesgo

Se calcula la gravedad utilizando marcos estándar (como CVSS), considerando la facilidad de descubrimiento, la exposición de la falla, la capacidad de registrar/auditar el evento y el impacto técnico en la confidencialidad, integridad y disponibilidad (CIA).

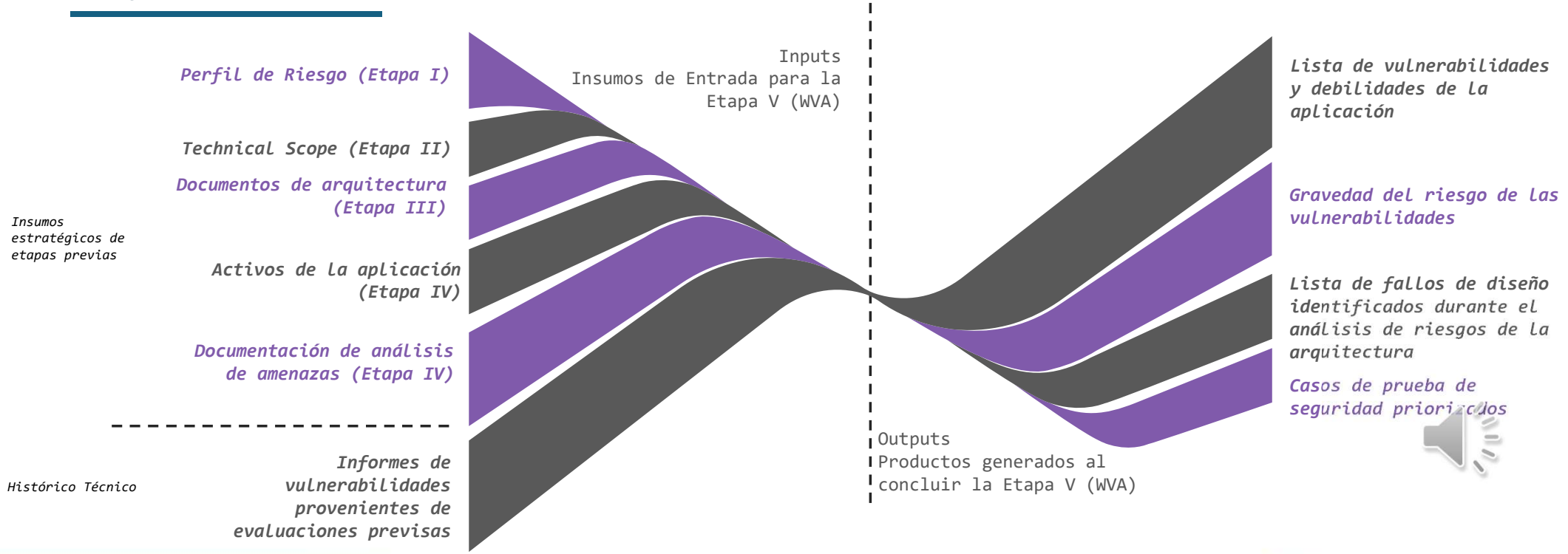
Matriz de correspondencia (Amenaza - Vulnerabilidad - Control)

Se vincula cada amenaza con las vulnerabilidades y fallas de diseño correspondientes.

5.2 Las 7 Etapas de PASTA

Etapa V: Análisis de debilidades y vulnerabilidades (WVA)

Artefactos de Entrada - Salida



5.2 Las 7 Etapas de PASTA

Etapa V: Análisis de debilidades y vulnerabilidades (WVA)

Actividades

WVA 5.1 – Revisión y correlación de vunerabilidades existentes

Revisar las vulnerabilidades de la aplicación que afectan a los controles de seguridad encargados de proteger activos.

WVA 5.2 – Identificar patrones de diseño débiles en la arquitectura

Analizar el alcance del control de seguridad y verificar que se cumplan los requisitos para un diseño seguro de los controles, la arquitectura de la aplicación y su funcionalidad.

WVA 5.3 – Mapeo de amenazas a vulnerabilidades

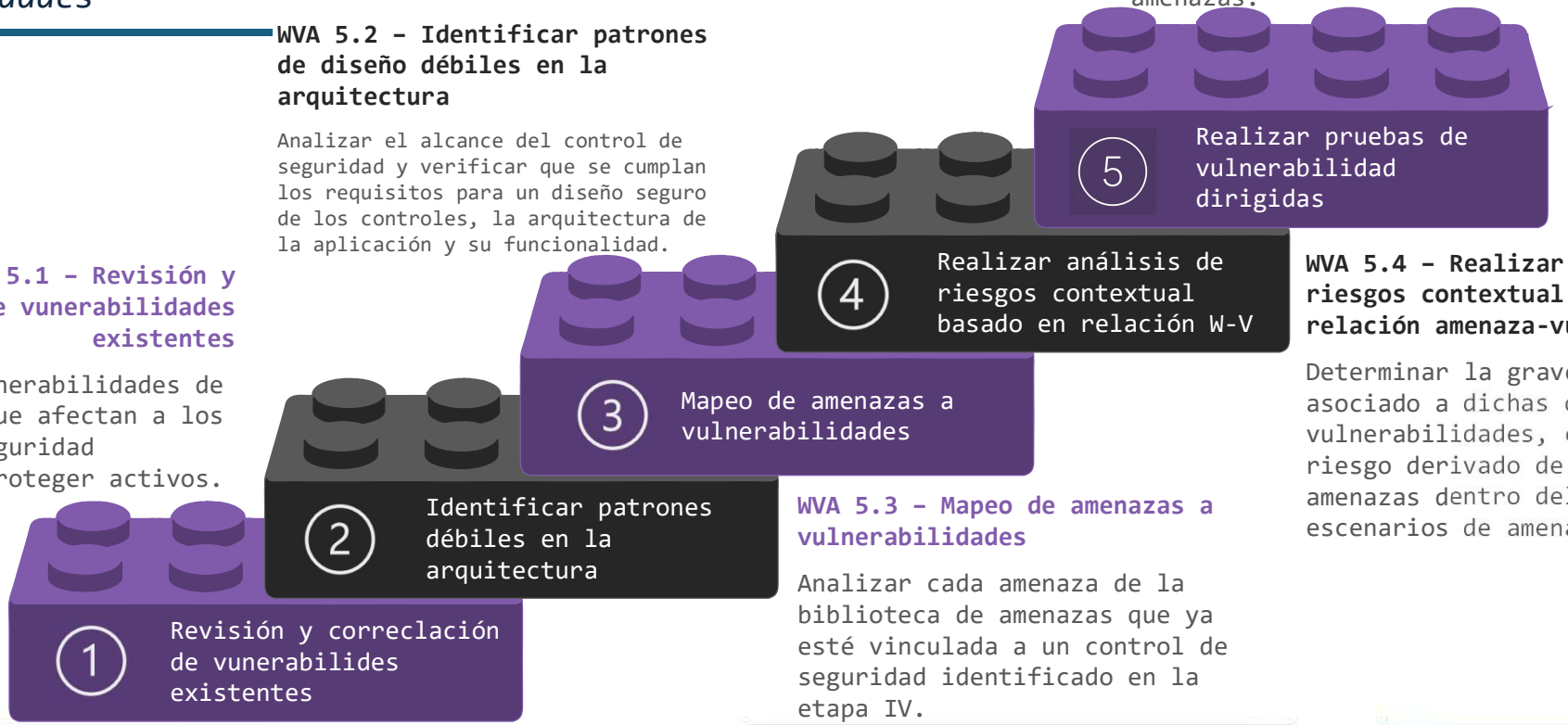
Analizar cada amenaza de la biblioteca de amenazas que ya esté vinculada a un control de seguridad identificado en la etapa IV.

WVA 5.4 – Realizar un análisis de riesgos contextual basado en la relación amenaza-vulnerabilidad

Determinar la gravedad del riesgo asociado a dichas debilidades y vulnerabilidades, considerando el riesgo derivado de la exposición a amenazas dentro del marco de los escenarios de amenaza generales.

WVA 5.5 – Realizar pruebas de vulnerabilidad dirigidas

Crear un conjunto de pruebas de seguridad para debilidades y vulnerabilidades específicas a las que apuntan los agentes de amenazas.



5.2 Las 7 Etapas de PASTA

Etapa VI: Modelado y simulación de ataques (AMS)

Esta etapa evalúa, simula y prueba las amenazas dirigidas a una aplicación

Análisis de escenarios

Detectar fallas en la arquitectura del sistema e integrar hallazgos de evaluaciones previas.

Actualización de vectores

Cruzar las vulnerabilidades encontradas con las amenazas previamente analizadas.

Simulación y pruebas

Clasificar las debilidades clave para determinar cuáles deben ser probadas o validadas.

5.2 Las 7 Etapas de PASTA

Etapa VI: Modelado y simulación de ataques (AMS)

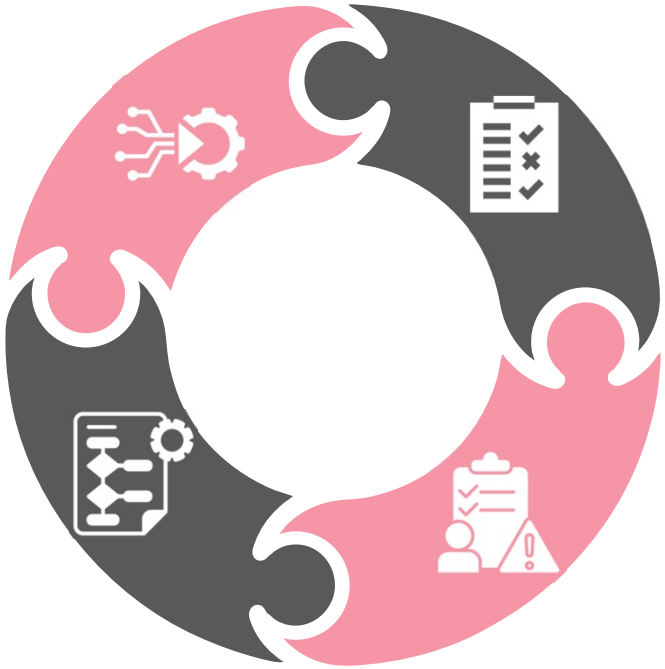
Guia de Ejecución

Fuentes de entrada y enfoque

Se utilizan las amenazas, agentes y TTP identificados previamente para evaluar tanto ataques dirigidos como la explotación oportunista de vulnerabilidades en la pila tecnológica de la aplicación.

Técnicas de modelado

Es el uso de árboles de ataque y casos de abuso para identificar las rutas más probables del atacante y determinar cómo este puede manipular los flujos del negocio para eludir los controles de seguridad.



Resultados y entregables

Concluye con la ejecución de simulaciones basadas en las rutas de ataque más probables, la definición de controles de detección y respuesta, y la actualización de la biblioteca de ataques.

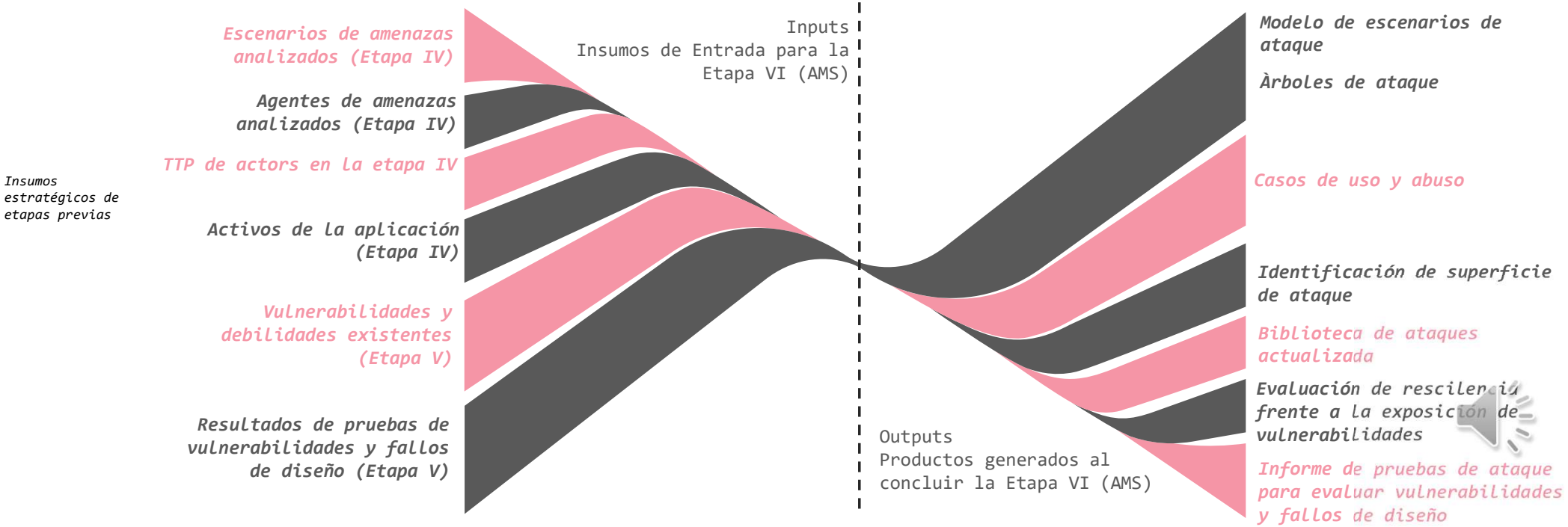
Evaluación de riesgo

Calcula la probabilidad de éxito de un ataque considerando los recursos del agresor frente al impacto técnico y la pérdida económica para el negocio.

5.2 Las 7 Etapas de PASTA

Etapa VI: Modelado y simulación de ataques (AMS)

Artefactos de Entrada - Salida



5.2 Las 7 Etapas de PASTA

Etapa VI: Modelado y simulación de ataques (AMS)

Actividades

AMS 6.6 – Realizar pruebas de seguridad y simulaciones basadas en ataques

Pone en práctica los escenarios definidos para validar empíricamente la seguridad de la aplicación.

AMS 6.5 – Derivar un conjunto de casos para probar las contramedidas existentes

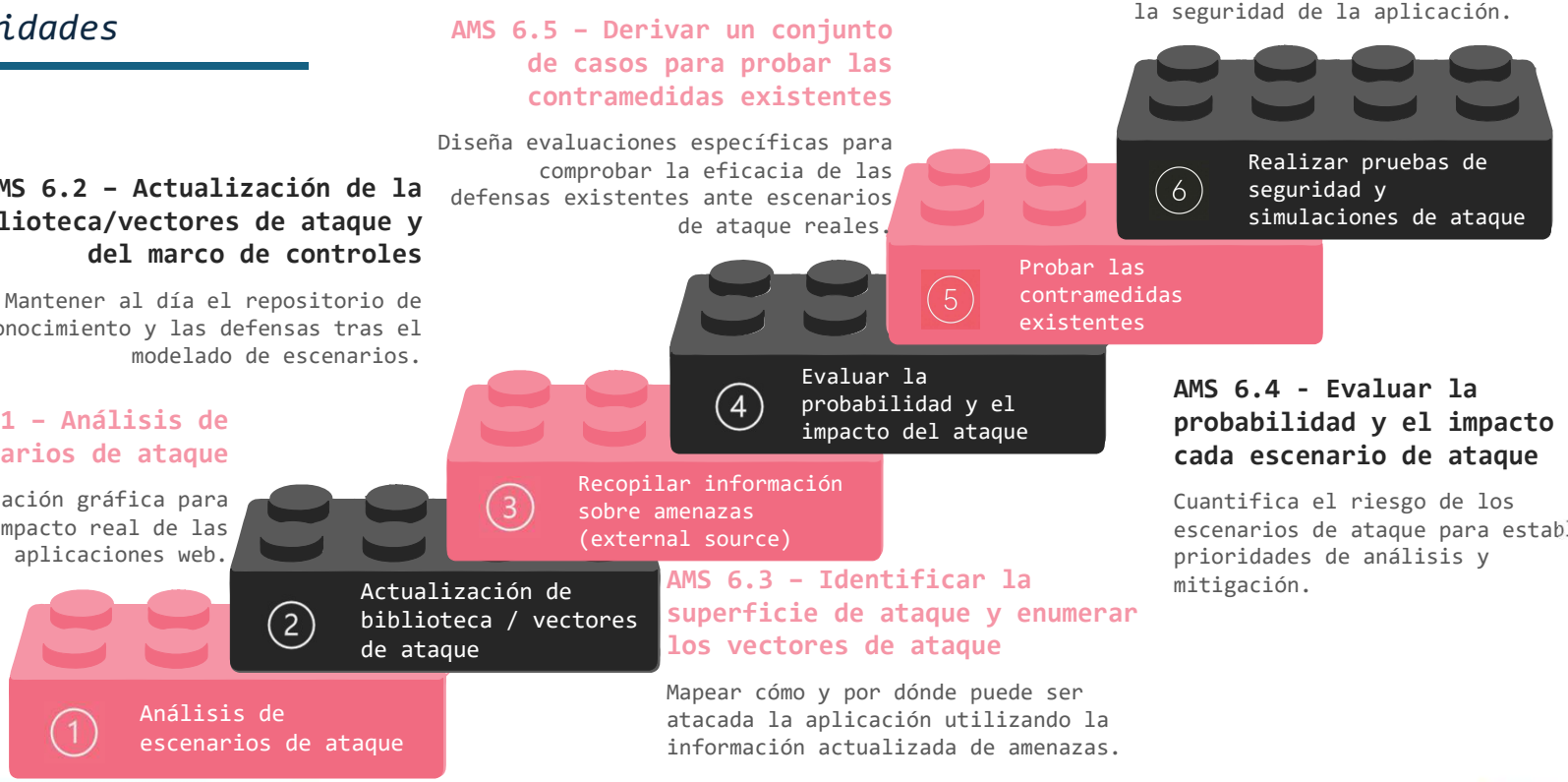
Diseña evaluaciones específicas para comprobar la eficacia de las defensas existentes ante escenarios de ataque reales.

AMS 6.2 – Actualización de la biblioteca/vectores de ataque y del marco de controles

Mantener al día el repositorio de conocimiento y las defensas tras el modelado de escenarios.

AMS 6.1 – Análisis de escenarios de ataque

Representación gráfica para identificar el impacto real de las aplicaciones web.



AMS 6.3 – Identificar la superficie de ataque y enumerar los vectores de ataque

Mapear cómo y por dónde puede ser atacada la aplicación utilizando la información actualizada de amenazas.

AMS 6.4 - Evaluar la probabilidad y el impacto de cada escenario de ataque

Cuantifica el riesgo de los escenarios de ataque para establecer prioridades de análisis y mitigación.

5.2 Las 7 Etapas de PASTA

Etapa VII – Análisis y gestión de riesgos (RAM)

Esta etapa evalúa el impacto de los ataques y amenazas simulados para definir su tratamiento

Cálculo del riesgo inicial

Evalúa de forma cualitativa y cuantitativa el riesgo de cada amenaza identificada

Determinación del riesgo residual

Mide el riesgo restante tras proyectar la aplicación de contramedidas y evaluar su eficacia.

Propuesta de estrategias

Recomienda mitigaciones y acciones concretas para reducir el impacto técnico y empresarial de los riesgos.

5.2 Las 7 Etapas de PASTA

Etapa VII – Análisis y gestión de riesgos (RAM)

Guia de Ejecución

Evaluación de impactos

Calcula el nivel de riesgo analizando la probabilidad de ocurrencia de los impactos técnicos y empresariales.

Propuesta de contramedidas

Asignar riesgos a los escenarios simulados y recomienda correcciones de diseño o parches para las vulnerabilidades encontradas.



Análisis coste-beneficio y riesgo residual

Considera el coste total de propiedad de las soluciones para que sea proporcional al daño potencial, evaluando la eficacia conjunta y el riesgo residual final para alinearse con los objetivos estratégicos fijados en la Etapa I.

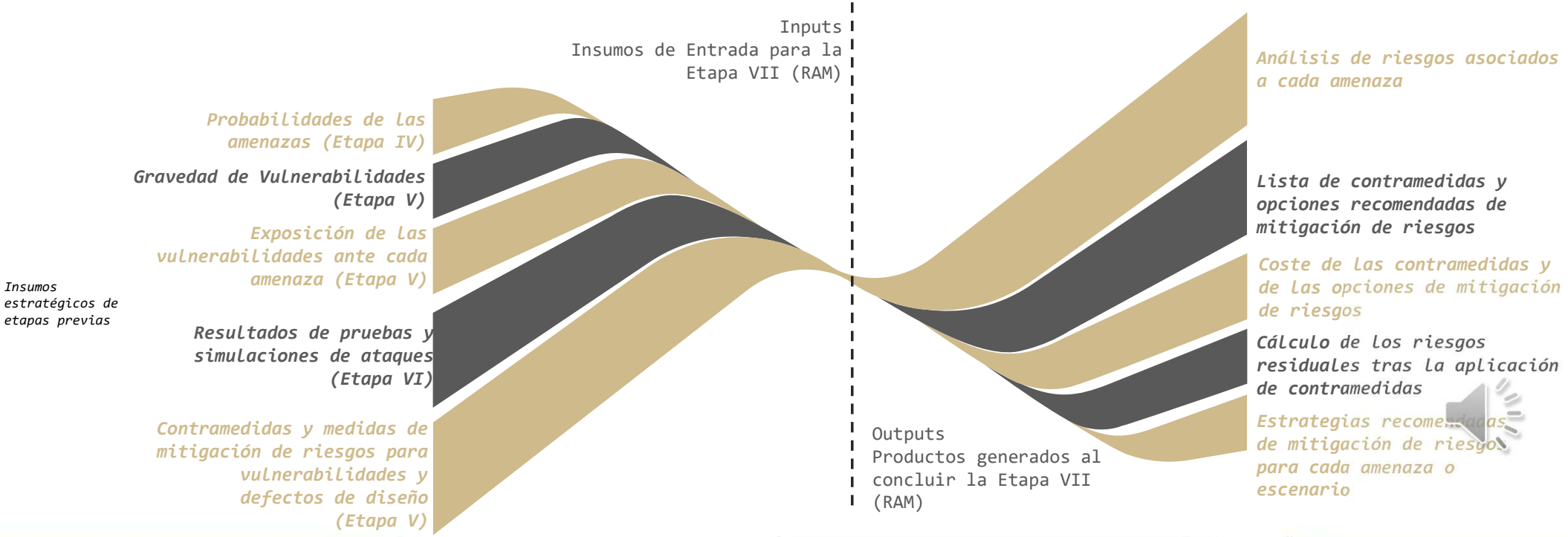
Estrategias de gestión del riesgo

Mitigar -> Transferir -> Aceptar

5.2 Las 7 Etapas de PASTA

Etapa VII – Análisis y gestión de riesgos (RAM)

Artefactos de Entrada - Salida



5.2 Las 7 Etapas de PASTA

Etapa VII – Análisis y gestión de riesgos (RAM)

Actividades

RAM 7.1 – Calcular el riesgo de cada amenaza

Determina el riesgo de cada amenaza combinando la probabilidad de ocurrencia con la evaluación de sus impactos técnico y financiero sobre los activos.

RAM 7.2 – Recomendación de contramedidas y mitigación de riesgos

Proteger los activos de la aplicación mediante controles preventivos y de detección, y corrección causa-raíz.



RAM 7.3 – Cálculo de los riesgos residuales

Evaluar el nivel de riesgo remanente tras la implementación de contramedidas y soluciones correctivas en producción:

RAM 7.4 – Recomendar estrategias de gestión de riesgos

Definir las acciones finales para el tratamiento de los riesgos y la mitigación de sus consecuencias